HashiCorp Certified: Terraform Associate（004）　目標 8b・8c　#16

HCP Terraformの共同作業とガバナンス

プロジェクトと Default Project、変数セットと優先順位、run trigger、リモートステートの共有と tfe_outputs、チームとワークスペースの権限、動的なプロバイダーの資格情報、ポリシー（Sentinel・OPA）と強制レベル、ヘルス評価、プライベートレジストリ、Explorer、change requests

各ページの下に、根拠にした資料（HashiCorp の Exam Content List（004）、HCP Terraform ドキュメントの Projects Overview・Project Best Practices・Run triggers・Variables overview・Workspace settings・Teams overview・Workspace permissions・Dynamic provider credentials・Policy enforcement overview・Manage policy sets・Health assessments・Private registry overview・Explorer・Change requests overview）を書いた。英語の原文は『』で引用した

第1章

プロジェクトとワークスペースの整理

まとめる・配る・つなぐ。

プロジェクトと変数セット

組織（owners チーム）

↓

プロジェクト
ワークスペースをまとめ、チームの権限の範囲に。Default Project は消せない

↓

ワークスペース
必ず 1 つのプロジェクトに入る

本番のネットワークと開発の計算資源は別のプロジェクトに。TFE プロバイダーで自動化、ランディングゾーンのプロジェクト。

変数セットの範囲	付く先
ワークスペース	選んだワークスペース
プロジェクト	今と将来の全ワークスペース
グローバル	組織の今と将来の全ワークスペース

優先順位：priority の変数セット ＞ -var・-var-file ＞ TF_VAR_ ＞ ワークスペース固有 ＞ 範囲つきの変数セット ＞ グローバル ＞ *.auto.tfvars

同じ範囲の変数セットどうしは名前の辞書順で先（A_ が B_ に勝つ）。

出典：Projects Overview／Project Best Practices／Variables overview

run trigger とステートの共有

networking-prod（元）
apply 成功

↓ run trigger

app-prod（自分）
実行が自動で積まれる

run trigger の決まり
元のワークスペースは 20 まで
設定はワークスペースの管理者
自動 apply は「Auto-apply run triggers」（別の設定）

リモートステートの共有
組織のすべて
同じプロジェクトのすべて
指定したワークスペース（新しいワークスペースの既定・一覧は空）

最小権限：必要なワークスペースだけに許す。

出力を読むなら tfe_outputs がすすめ（terraform_remote_state はステート全体の権限が要る）。

出典：Run triggers／Workspace settings（Remote State Sharing）

第2章

チーム・権限・資格情報

だれが、何を、どの資格情報で。

チームとワークスペースの権限

権限	できること
Read	実行・変数・ステートを読む
Plan	＋ plan を始める（apply は承認が必要な人向け）
Write	＋ apply、変数・ステートの読み書き、ロック（日々の構築）
Admin	＋ 設定（run trigger など）・チームの権限・削除

custom で細かく選べる。ステートは「出力だけ読む」にも絞れる。

チーム
組織の中のユーザーのグループ。権限は自分の組織のワークスペースだけ

ユーザー
複数の組織の複数のチームに入れる

owners チーム
組織の全権。削除も空にもできない

チームの API トークン：特定のユーザーに結びつかない。

出典：Teams overview／Workspace permissions

動的なプロバイダーの資格情報

1. HCP がワークロード ID トークンを作る
OIDC 準拠。組織・ワークスペース・実行の段階を含む

↓

2. クラウドに送り、公開鍵で確かめる

↓

3. 一時的な資格情報で plan・apply
終わったら実行の環境ごと捨てる

設定の手順
1 クラウドと HCP Terraform の信頼関係
2 クラウドのロール・ポリシー
3 ワークスペースの環境変数（変数セットでも）

静的な資格情報は、ローテーションしていても危険。動的なら手での管理・ローテーションが要らない。

AWS・Azure・GCP・Vault などに対応。

出典：Dynamic provider credentials

第3章

ガバナンス

ルールで止める、定期的に見守る、全体を見わたす。

ポリシーと強制レベル

Sentinel	失敗したとき
advisory	止めない（知らせるだけ）
soft mandatory	止める。許された人は override で続行
hard mandatory	直すまで apply しない（セットで許せば上書き可）

OPA（Rego）	失敗したとき
advisory	止めない
mandatory	止める。Manage Policy Overrides の人は上書き可

ポリシーセット
組織全体・プロジェクト・ワークスペースに付ける。1 つのセットに 1 つのフレームワーク

実行ごとに plan を照らす
スペキュラティブプランとリモートの apply

ポリシーは VCS に置く（標準化・セキュリティ・監査）。

CLI 駆動の実行で結果が端末に出るのは Sentinel だけ。

出典：Policy enforcement overview／Manage policy sets／The CLI-driven remote run workflow

見守る・共有する機能

機能	何をするか	覚えどころ
ドリフト検出	実物が設定と合っているか	構成のドリフトだけ（ステートのドリフトは見ない）
継続的な検証	precondition・postcondition・check が通りつづけるか	check ブロックがすすめ。v1.3〜
プライベートレジストリ	組織の中でモジュール・プロバイダーを共有	版の管理と検索できる一覧
Explorer	組織中のワークスペース・モジュール・プロバイダー・版を一覧	ドリフトしたもの、古い版、VCS なし
change requests	ワークスペースに「やること」を記録して知らせる	Explorer の結果から作り、終われればアーカイブ

> ヘルス評価（ドリフト検出＋継続的な検証）の設定を変えるのはワークスペースの管理者。

出典：Health assessments／Private registry overview／Explorer for workspace visibility／Change requests overview

本番での問われ方

ねらい	見るところ
プロジェクト（8c）	ワークスペースは必ず 1 つ、Default Project、権限の範囲、既定の実行モード
変数セット（8c）	ワークスペース・プロジェクト・グローバル、ワークスペース固有が勝つ、辞書順
run trigger（8c）	元の apply 成功で積む、20 まで、自動 apply は別の設定、tfe_outputs
共同作業（8b）	チームと Read・Plan・Write・Admin、動的な資格情報（OIDC・一時的）
ガバナンス（8b）	Sentinel の 3 段階と OPA の 2 段階、ヘルス評価、プライベートレジストリ、Explorer、change requests

出典：Exam Content List（004）8b・8c／本資料の問題演習（全 30 問）